

# EVALUACIÓN DE RIESGO DE TERCEROS (TPRM)

## TecnoSoluciones IT S.L.

— Actividad Práctica de Ciberseguridad —

|                       |                                                                      |
|-----------------------|----------------------------------------------------------------------|
| Autora                | María José Gómez Spandonari                                          |
| Perfil                | Alumna de Ciberseguridad                                             |
| Empresa simulada      | CloudHealth Canarias S.L.                                            |
| Proveedor evaluado    | TecnoSoluciones IT S.L. — Servicios Gestionados de TI                |
| Fecha                 | Julio 2026                                                           |
| Clasificación         | Uso educativo / Portfolio profesional                                |
| Documento relacionado | Marco Documental de Seguridad — Política #4 (Gestión de Proveedores) |

### PARTE 1 — CONTEXTO Y ALCANCE

Esta evaluación desarrolla la Política #4 (Gestión de Proveedores y Terceros) del Marco Documental de Seguridad de CloudHealth Canarias S.L., que identificó el acceso no supervisado del proveedor externo de TI como un riesgo pendiente de análisis detallado.

#### Servicio prestado

TecnoSoluciones IT S.L. presta servicios de soporte de infraestructura TI y helpdesk para CloudHealth Canarias S.L., incluyendo mantenimiento de servidores, soporte de puestos de trabajo y acceso remoto para tareas administrativas.

#### Sistemas y datos accesibles

- Acceso administrativo/privilegiado a servidores de infraestructura
- Sistemas que alojan la base de datos de historiales clínicos (acceso indirecto a datos de categoría especial RGPD)
- Cuentas de usuario y sistemas de autenticación
- Equipos y tablets del personal sanitario

Es importante señalar que el proveedor no necesita acceder directamente a los datos clínicos para representar un riesgo crítico: el acceso a nivel de infraestructura es, en muchos casos, más peligroso que el acceso a nivel de datos, ya que una cuenta de soporte TI comprometida puede utilizarse para alcanzar cualquier sistema de la red, no solo uno.

### PARTE 2 — METODOLOGÍA DE EVALUACIÓN

#### Riesgo inherente vs. riesgo residual

El riesgo inherente mide el nivel de riesgo que representa la relación con el proveedor únicamente en base al tipo de acceso y la sensibilidad de los datos implicados, sin tener en cuenta los controles existentes. El riesgo residual mide el riesgo que permanece una vez aplicados los controles actualmente en vigor. La diferencia entre ambos valores indica si los controles compensatorios existentes están reduciendo el riesgo de forma efectiva.

Escala de puntuación: 1 = Bajo, 2 = Moderado, 3 = Alto, 4-5 = Crítico (por categoría).

El riesgo inherente se evalúa mediante cinco categorías: Sensibilidad de Datos, Nivel de Acceso, Criticidad para el Negocio, Exposición Regulatoria y Dependencia de la Cadena de Suministro. El riesgo residual se evalúa utilizando las seis funciones del marco NIST CSF 2.0 (Govern, Identify, Protect, Detect, Respond, Recover), lo que permite reutilizar la misma estructura de evaluación en futuros análisis de madurez de controles.

### PARTE 3 — EVALUACIÓN DE RIESGO INHERENTE

| Categoría | Puntuación (1-5) | Justificación |
|-----------|------------------|---------------|
|-----------|------------------|---------------|

|                                        |                |                                                                                                            |
|----------------------------------------|----------------|------------------------------------------------------------------------------------------------------------|
| Sensibilidad de Datos                  | 5              | Acceso a infraestructura que aloja historiales clínicos (categoría especial RGPD).                         |
| Nivel de Acceso                        | 5              | Acceso administrativo/privilegiado a todos los sistemas, no limitado ni segmentado.                        |
| Criticidad para el Negocio             | 4              | Soporte de infraestructura esencial para la operativa diaria de ambas clínicas.                            |
| Exposición Regulatoria                 | 5              | Un incidente causado por el proveedor generaría responsabilidad directa bajo RGPD/LOPDGDD.                 |
| Dependencia de la Cadena de Suministro | 4              | No existe proveedor alternativo identificado; una interrupción del servicio no tiene plan de contingencia. |
| <b>TOTAL</b>                           | <b>23 / 25</b> | <b>Nivel de riesgo inherente: CRÍTICO</b>                                                                  |

## PARTE 4 — EVALUACIÓN DE RIESGO RESIDUAL (NIST CSF 2.0)

| Función CSF     | Pregunta de Control                                                                           | Hallazgo                                                                                                                     | Puntuación     |
|-----------------|-----------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------|----------------|
| <b>Govern</b>   | ¿Existe un acuerdo de nivel de servicio (SLA) de seguridad firmado?                           | No existe SLA de seguridad formal en el contrato actual.                                                                     | <b>1</b>       |
| <b>Identify</b> | ¿Está documentado y revisado periódicamente el alcance de acceso del proveedor?               | El acceso se concedió de forma puntual, sin revisión posterior.                                                              | <b>2</b>       |
| <b>Protect</b>  | ¿Utiliza el proveedor MFA y acceso de mínimo privilegio en sus sesiones remotas?              | No confirmado; no se ha solicitado evidencia formal al proveedor.                                                            | <b>2</b>       |
| <b>Detect</b>   | ¿Se registra y supervisa la actividad de acceso remoto del proveedor?                         | No existe monitorización ni alertas específicas para las sesiones del proveedor.                                             | <b>2</b>       |
| <b>Respond</b>  | ¿Define el contrato plazos de notificación de incidentes si el proveedor los causa o detecta? | No especificado en el contrato actual.                                                                                       | <b>2</b>       |
| <b>Recover</b>  | ¿Existe un proceso definido para revocar el acceso del proveedor de forma inmediata?          | No existe un proceso de baja documentado para cuentas de proveedores (a diferencia del proceso ya existente para empleados). | <b>2</b>       |
| <b>TOTAL</b>    |                                                                                               | <b>Nivel de riesgo residual: ALTO</b>                                                                                        | <b>11 / 30</b> |

El hallazgo más grave corresponde a la función Govern: la ausencia total de un SLA de seguridad implica que no existe ningún mecanismo contractual para exigir el cumplimiento del resto de controles, incluso si algunos existieran de forma informal. Un control de gobernanza ausente limita el crédito que puede otorgarse a los controles técnicos, ya que sin una obligación contractual no hay forma de garantizar que esos controles se mantengan en el tiempo.

## PARTE 5 — DECISIÓN DE TRATAMIENTO DE RIESGO

El marco de tratamiento de riesgo contempla cuatro opciones: Mitigar (reducir el riesgo mediante controles adicionales), Aceptar (asumir el riesgo sin acción adicional, cuando es bajo), Transferir (trasladar el impacto financiero mediante seguro o contrato) o Terminar (finalizar la relación con el proveedor).

### Decisión: MITIGAR

Se descarta Aceptar por tratarse de un riesgo residual ALTO. Se descarta Terminar porque el proveedor presta un servicio esencial sin alternativa inmediata identificada, y no existe evidencia de mala fe o incumplimiento deliberado, solo ausencia de gobernanza formal — un problema corregible. Transferir no resulta aplicable de forma aislada, ya que no elimina el riesgo de acceso indebido a los sistemas. La vía de Mitigar mediante la hoja de ruta de remediación (Parte 6) es la opción más proporcionada.

## PARTE 6 — HOJA DE RUTA DE REMEDIACIÓN

| Prioridad | Acción                                                                                                                                            | Responsable                          | Plazo   |
|-----------|---------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------|---------|
| <b>P0</b> | Redactar y firmar un SLA de seguridad que incluya requisitos de MFA, registro de accesos y notificación de incidentes en 72h (alineado con RGPD). | Responsable de Seguridad / Dirección | 15 días |
| <b>P1</b> | Ampliar el proceso de revisión de cuentas ya existente para empleados de forma que incluya                                                        | Responsable de Seguridad / TI        | 30 días |

|           |                                                                                                                                     |                          |                  |
|-----------|-------------------------------------------------------------------------------------------------------------------------------------|--------------------------|------------------|
|           | explícitamente las cuentas del proveedor.                                                                                           |                          |                  |
| <b>P1</b> | Activar registro centralizado (logging) de todas las sesiones de acceso remoto del proveedor.                                       | TI                       | 30 días          |
| <b>P2</b> | Exigir y verificar evidencia documental de que el proveedor aplica MFA y principio de mínimo privilegio.                            | Responsable de Seguridad | 90 días          |
| <b>P3</b> | Repetir esta evaluación de riesgo de forma anual, o inmediatamente ante cualquier cambio relevante en la relación con el proveedor. | Responsable de Seguridad | Anual / continuo |

## CONCLUSIÓN

La evaluación revela un riesgo inherente CRÍTICO (23/25), consecuencia directa del nivel de acceso privilegiado del proveedor a sistemas que alojan datos de categoría especial. Los controles actualmente en vigor reducen el riesgo a un nivel ALTO (11/30), pero no lo suficiente: la carencia estructural es la ausencia de un SLA de seguridad formal, que socava la eficacia de cualquier control técnico existente.

Esta evaluación proporciona el análisis de riesgo detallado y las acciones de remediación específicas que la Política #4 (Gestión de Proveedores) del Marco Documental de Seguridad requería pero no desarrollaba, demostrando cómo ambos documentos funcionan como un sistema de gobernanza conectado, no como ejercicios aislados.